

Table of Contents

Manual prático de registro de risco e tratamento de risco do GRC

Versão 1.0 — Agosto de 2026

Autor: Alberto “Al” Leiva

O ChatGPT ajudou sob a direção do autor. O autor permanece responsável pelas decisões editoriais e de divulgação.

Aviso de utilização da educação

Este manual e suas ferramentas acompanhantes são recursos educacionais. Eles devem ser adaptados aos objetivos da organização, apetite de risco, obrigações legais e contratuais, sistemas, dados, autoridade de decisão e contexto operacional. Não constituem aconselhamento jurídico, contábilístico, regulamentar, de certificação ou de auditoria formal.

Como utilizar este manual

Utilizar os capítulos para estabelecer um novo registro de risco. Programas existentes podem usar seções individuais para a qualidade do cenário, pontuação, tratamento, aceitação, monitoramento ou melhoria da governança. Preservar a lógica, evidência, propriedade, aprovações e revisar o histórico para cada decisão de risco material.

1. Fundações de Gestão de Risco

Objecto

Um registro de risco é um registro de decisão controlado. Documenta eventos ou condições incertas que poderiam afetar objetivos, as evidências utilizadas para avaliá-los, a resposta selecionada por líderes responsáveis e as ações necessárias para manter a exposição dentro dos limites aprovados.

Um registro deve apoiar as decisões em vez de se tornar uma lista estática de preocupações. Cada entrada deve ser específica o suficiente para que outra pessoa qualificada possa compreender o cenário, reproduzir a lógica de avaliação, identificar o proprietário responsável e determinar se o tratamento está progredindo.

Conceitos principais

Objectivo

O negócio, missão, serviço, conformidade, segurança, segurança, privacidade, financeiro ou resultado operacional que pode ser afetado.

Cenário de risco

Uma descrição concisa de como uma ameaça, condição, dependência, decisão ou oportunidade poderia afetar um objetivo. Uma estrutura útil é:

Devido a ** causa ou condição, evento** pode ocorrer, resultando em ** consequência para um objetivo**.

Risco inerente

A exposição estimada antes de considerar a eficácia dos controlos existentes. As organizações devem definir se o risco inerente não assume nenhum controle, apenas controles de base, ou outra condição declarada.

Controlos existentes

Políticas, processos, tecnologias, contratos, formação, supervisão ou outras medidas já em funcionamento para modificar a probabilidade ou o impacto.

Risco residual

A exposição remanescente após considerar a concepção e a eficácia operacional dos controlos existentes.

Risco-alvo

A exposição esperada após as ações de tratamento aprovadas é concluída e verificada.

Risco de apetite e tolerância

O apetite de risco expressa a quantidade e o tipo de risco que uma organização está disposta a perseguir ou manter em apoio dos objetivos. A tolerância estabelece limites mensuráveis ou variações aceitáveis em torno desses objetivos. As entradas de tolerância externa requerem aumento, tratamento, transferência, evitação ou aceitação formalmente autorizada.

Princípios de governação

1. Vincular cada risco material a um objetivo.
2. Atribuir um responsável proprietário de risco, mesmo quando muitas equipas contribuem.
3. Provas separadas do julgamento.
4. Incerteza do Estado e pressupostos explicitamente.
5. Use escalas definidas de forma consistente.
6. Não mediar as consequências graves sem justificação documentada.

7. Registrar quem aceitou o risco residual e o período de aceitação.
8. Reavalia após mudanças materiais, incidentes, falhas de controle ou novas informações.
9. Manter a rastreabilidade para apoiar provas e questões conexas.
10. Escale o tratamento atrasado e a aceitação expirada automaticamente ou através de um processo de revisão documentado.

Funções

A responsabilidade principal - Oh, meu Deus. ☐ Órgão de administração ou comitê executivo
Aprova o apetite, a tolerância e as principais decisões de risco O proprietário do risco é responsável pela compreensão e gestão do risco ☐ Controlar o proprietário ☐ Contabilizável para o projeto, operação e evidência de um controle O proprietário da ação ☐ Completa uma tarefa de tratamento específica Função de risco Define metodologia, avaliações de desafios e relatórios de exposição à carteira ☐ Função de garantia ☐ Avalia independentemente a governança, os controles e as evidências Especialista em matéria de matérias de assunto ☐ Fornece informações técnicas, legais, operacionais, financeiras ou de outros especialistas

Ensaio de qualidade mínima

Uma entrada de risco não está pronta para aprovação, a menos que identifique o objetivo afetado, descreva um cenário plausível, cite evidências, atribua um proprietário, registre controles atuais, avalie probabilidade e impacto utilizando critérios definidos, declare exposição residual, selecione uma resposta e inclua uma data de revisão.

2. Identificação de Risco e Escrita de Cenários

Identificar os riscos decorrentes dos objetivos

Comece com o objetivo, não com uma lista de ameaças genéricas. Reveja objetivos estratégicos, serviços críticos, obrigações legais e contratuais, ativos-chave, dados importantes, principais terceiros, projetos, mudanças e dependências conhecidas.

As entradas de identificação úteis incluem:

- Objetivos empresariais e de missão
- Análises de impacto empresarial
- Arquitetura e diagramas de fluxo de dados
- Existências de activos e de serviços
- Informações sobre ameaças e história de incidentes
- Resultados da auditoria e dos testes de controlo
- Vulnerabilidade e dados de configuração
- Avaliação do fornecedor e do risco de concentração
- Requisitos regulamentares e contratuais
- Alterar carteiras e planos de transformação
- Queixas, quase faltas, exceções e eventos de perda

Estrutura do cenário

Um cenário de risco defensável contém quatro elementos:

1. **Contexto ou causa** — a condição que cria exposição.
2. **Evento** — o que pode acontecer.
3. **** Objetivo ou ativo afetado **** — o que importa para a organização.
4. **** Consequência **** — o dano credível ou oportunidade perdida.

Exemplo:

Como as contas privilegiadas não são revistas de forma consistente, um privilégio não autorizado ou excessivo pode permanecer ativo, permitindo o acesso inadequado a informações sensíveis do cliente e causando danos regulatórios, financeiros e de reputação.

Evite declarações fracas

As entradas fracas incluem palavras únicas como “resgates”, “risco de venda”, ou “não conformidade”. Não explicam as consequências comerciais nem apoiam uma avaliação repetitiva.

Reescrever declarações vagas perguntando:

- Que condição torna o evento possível?
- Que evento poderia ocorrer?
- Qual objetivo, serviço, ativo ou obrigação é afetado?
- Qual é a consequência credível?
- Que provas apoiam o cenário?

Taxonomia de risco

Uma taxonomia ajuda a agregar entradas sem substituir a análise de nível de cenário. As categorias podem incluir:

- Estratégico
- Operacional
- Cibersegurança
- Privacidade
- Jurídica e regulamentar
- Financeiro
- Tecnologia
- Terceiros e cadeias de abastecimento
- Resiliência e continuidade
- Segurança
- Força de trabalho
- Reputação

- Projeto e mudança

Use categorias primárias e secundárias quando um cenário abrange vários domínios.

Provas e pressupostos

Cada cenário material deve citar evidências como relatórios, tickets, avaliações, contratos, resultados de testes, registros de incidentes, métricas ou análise de especialistas. Registrar os pressupostos separadamente para que os decisores possam distinguir os factos conhecidos das estimativas.

Exemplos de pressupostos:

- Um serviço permanecerá dependente de um prestador durante os próximos doze meses.
- Um controle funciona conforme projetado entre testes trimestrais.
- Uma estimativa de frequência de ameaça baseia-se em dados do setor e não em histórico interno.

Identificadores de entrada e relações

Atribuir identificadores estáveis como RR - 2026 - 001. Não reciclar identificadores. Registos relacionados com a ligação, incluindo:

- Controlos
- Resultados
- Incidentes
- Excepções
- Projectos
- Produtores
- Activo
- Políticas
- Acções de tratamento
- Decisões de risco aceites

Método da oficina de identificação

1. Defina o objetivo e o escopo.
2. Apresentar provas atuais e restrições conhecidas.
3. Identificar causas, eventos e consequências.
4. Consolide duplicatas sem perder causas ou impactos distintos.
5. Atribuir proprietários provisórios.
6. Suposições documentais e lacunas de provas.
7. Envie entradas para validação antes de marcar.

Um workshop não deve forçar o consenso através da média de pontos de vista incompatíveis. O desacordo material deve ser registrado e aumentado para decisão.

3. Análise de Risco e Pontuação

Definir o método antes da pontuação

As organizações devem documentar seus critérios de probabilidade, impacto e nível de risco antes de avaliar as entradas individuais. Um modelo de pontuação suporta priorização, mas não substitui julgamento profissional ou decisões de governança.

Escala de probabilidade

Uma escala prática de cinco níveis pode utilizar a frequência, probabilidade ou evidência qualitativa.

Tradução por exemplo

☐ 1 * Raros * Circunstâncias excepcionais; pouca evidência de apoio * ☐ 2 - Improvável - Pode ocorrer, mas não é esperado em condições normais ☐ 3 ☐ Possível ☐ Credível e pode ocorrer durante o período de avaliação ☐ 4 É provável que tenha ocorrido ou tenha ocorrido repetidamente ☐ 5 Quase certo, esperado frequentemente ou já ocorrendo

A organização deve definir o período de avaliação e limiares mensuráveis quando os dados permitirem.

Escala de impacto

Avaliar o impacto nas dimensões relevantes e, em seguida, aplicar a regra de agregação documentada.

Tradução geral ☐

☐ 1 ☐ Interrupção ou perda mínima; manipulação de rotina ☐ 2 menor impacto limitado; gerenciável dentro de operações normais ☐ 3 ☐ Moderado ☐ Disrupção de material, custo, ou preocupação de conformidade exigindo atenção de gestão ☐ 4 Maiores danos a objetivos, clientes, operações, finanças, ou obrigações ☐ 5 ☐ Graves consequências de risco para a empresa, segurança de vida, sistêmicas ou catastróficas

As dimensões comuns de impacto incluem o impacto financeiro, operacional, legal e regulatório, privacidade, segurança, cliente, estratégico e reputacional.

Pontuações compostas

Uma matriz simples pode calcular:

$\text{Risk score} = \text{Likelihood} \times \text{Impact}$

Bandas de exemplo:

- 1–4: Baixo
- 5–9: Moderado
- 10–16: Alta

- 17–25: Critical

Estas bandas são ilustrativas. A organização deve aprovar seus próprios limiares e regras de escalada.

Limitações importantes

Multiplicação pode criar falsa precisão. Um escore de 12 pode representar verossimilhança 3 e impacto 4 ou verossimilhança 4 e impacto 3, embora as implicações da governança possam diferir. Preservar as notações e a lógica subjacentes.

Não permita que uma baixa probabilidade de ocultar um impacto grave intolerável. Defina regras de substituição para segurança de vida, proibições legais, concentração sistêmica, falha de serviço crítico ou outras consequências não negociáveis.

Avaliação do controle

Avaliar o projeto de controle e a eficácia operacional separadamente.

- ** Eficácia do design: ** O controle, se funcionar como previsto, modificaria materialmente o risco?
- ** Eficácia operacional: ** O controle é implementado de forma consistente e apoiado pelas provas actuais?

Use datas de evidência, resultados de teste, exceções, cobertura e níveis de confiança. Não trate a existência de uma política como prova de que um controle funciona eficazmente.

Risco residual

O risco residual deve reflectir a eficácia avaliada dos controlos actuais. Gravar:

- Probabilidade residual
- Impacto residual
- Pontuação residual ou nível
- Confiança na estimativa
- Suposições-chave
- Data da prova
- Deficiências de controlo conhecidas

Confiança e incerteza

Adicione um campo de confiança, como alto, médio ou baixo. Os riscos de alto impacto de baixa confiança requerem frequentemente uma análise adicional e não uma prioridade mais baixa.

Questões de avaliação da qualidade

- As escalas são definidas e aplicadas de forma consistente?
- O período de avaliação está claro?
- As provas apoiam as audiências?

- Foram consideradas múltiplas dimensões de impacto?
- O desenho e a operação do controle foram avaliados separadamente?
- São visíveis incerteza e desacordo?
- O resultado se alinha com o apetite e a tolerância?

4. Resposta ao Risco, Tratamento e Aceitação

Selecione uma resposta

As respostas comuns incluem:

- **Evite:** Pare, reprojete ou recuse a atividade que cria a exposição.
- **Mitigação:** Reduza probabilidade, impacto ou ambos através de controles ou mudanças de processo.
- **Transfer or share:** Alocar consequências definidas para outra parte através de seguro, contrato, parceria ou outro mecanismo. A responsabilidade geralmente não pode ser transferida completamente.
- **Aceitar:** Manter a exposição residual através de uma decisão autorizada e com limite de tempo.
- **** Seguir ou melhorar: **** No que respeita ao risco relacionado com a oportunidade, tome medidas para aumentar a probabilidade ou o benefício, controlando simultaneamente a exposição negativa.

A resposta selecionada deve ser consistente com o apetite, tolerância, obrigações legais, contratos, ética e autoridade organizacional.

Requisitos do plano de tratamento

Um plano de tratamento deve identificar:

- A resposta e o raciocínio selecionados
- Risco-alvo desejado
- Acções e resultados específicos
- Donos de acções
- Recursos necessários e orçamento aprovado
- Dependências e restrições
- Marcos e datas de vencimento
- Medidas de sucesso
- Provas necessárias para o encerramento
- Efeito esperado sobre a probabilidade e o impacto
- Controlos provisórios quando o tratamento final levar tempo
- Critérios de escalada

Evite ações vagas, como “melhorar a segurança” ou “vender de monitoramento”. Escreva ações que podem ser testadas e fechadas.

Ensaio de qualidade da acção

Uma ação de tratamento é completa apenas quando existe a entrega necessária, o proprietário responsável fornece evidências, o controle ou mudança é validado, e o risco é reavaliado. Completar uma tarefa de projeto não prova automaticamente que o risco foi reduzido.

Aceitação do risco

A aceitação nunca deve ser implícita pela inação. Um registro formal de aceitação deverá incluir:

- Identificador do risco e nível residual atual
- Base do proprietário e da autoridade da decisão
- Fundamentação empresarial
- Aplicável apetite ou tolerância
- Condições e controlos compensadores
- Datas de início e de expiração da aceitação
- Requisitos de monitorização
- Eventos que requerem reconsideração precoce
- Notificações necessárias
- Assinatura ou prova de aprovação auditável

A aceitação expirada deve voltar ao estado de revisão até ser renovada, tratada, evitada, transferida ou fechada.

Excepções

Uma exceção de política ou controle pode criar ou aumentar o risco. Ligar exceções ao registro de risco relevante e incluir escopo, fundamentação, autoridade de aprovação, controles compensadores, data de expiração e plano de remediação.

Monitorização do tratamento

Faixa pelo menos:

- Acções abertas e atrasadas
- Estado do Marcone
- Alterações à exposição
- Controlo da aplicação e da prova de ensaio
- Restrições orçamentais ou de recursos
- Falhas na dependência
- Prazo de validade da aceitação
- Ameaças emergentes ou suposições alteradas

Critérios de encerramento

Um risco pode ser fechado quando o cenário não é mais aplicável, o objetivo ou atividade terminou, ou o tratamento verificado reduziu a exposição abaixo do limiar de fechamento da organização. Preservar o registro histórico, lógica de encerramento, evidência, aprovador e data de encerramento.

Não feche um risco apenas porque a data de vencimento passou ou o proprietário mudou.

5. Acompanhamento, relatórios e escalada

Frequência de revisão

A frequência de revisão deve refletir a exposição, volatilidade, status de tratamento e necessidades de decisão. Os riscos críticos ou em rápida mudança podem exigir uma revisão contínua ou mensal. Os riscos baixos estáveis podem ser revistos trimestral ou anualmente. Defina frequências mínimas e gatilhos de revisão orientados para eventos.

Reveja um risco precocemente quando:

- Um incidente significativo ou near miss ocorre
- Um controle falha ou as suas alterações de cobertura
- Um grande sistema, processo, fornecedor, lei, contrato ou mudanças objetivas
- Falta um marco de tratamento
- Uma aceitação aproxima-se da expiração
- Informações sobre ameaças ou perdas
- O risco ultrapassa o apetite ou a tolerância

Principais indicadores de risco

Um indicador de risco fundamental deve fornecer provas atempadas de que a exposição está a mudar. Cada indicador precisa de um proprietário, fonte, cálculo, limiar, frequência de coleta e regra de escalada.

Os exemplos incluem:

- Percentagem de sistemas críticos sem planos de recuperação testados
- Número de contas privilegiadas em atraso para revisão
- Concentração de serviços críticos com um prestador
- Vulnerabilidades de alta gravidade para além do período de reparação aprovado
- Percentagem de acções de tratamento em atraso
- Número de aceitações de risco expiradas

Situação e tendência

Acompanhe o nível atual e direção separadamente.

- **Melhorar:** Evidências indicam que a exposição está diminuindo.
- **** Estável:**** Nenhuma mudança de material.
- **Deterioração:** A exposição, incerteza, fraqueza de controle ou atraso está aumentando.
- **Desconhecido:** As evidências são insuficientes ou estagnadas.

Uma tendência desconhecida não equivale a um risco estável.

Escalção

Escalar quando um risco:

- Excede o apetite ou a tolerância
- Alcança um nível crítico
- Não tem proprietário responsável
- Está atrasado tratamento de alta prioridade
- Depende do financiamento ou autoridade não disponíveis
- Inclui uma proibição legal, preocupação de segurança ou obrigação de notificação obrigatória
- Tem uma aceitação expirada
- Mostra discordância material que não pode ser resolvida no nível atual

O registo deve identificar o beneficiário da escalada, o prazo necessário e a decisão solicitada.

Pontos de vista dos relatórios

Públicos diferentes precisam de visões diferentes.

Vista operacional

Inclui ações detalhadas, evidências, status de controle, datas de vencimento e dependências.

Vista de gestão

Destaca os principais riscos, tendências, tratamento atrasado, exceções e decisões necessárias.

Vista do corpo do governo

Foca na exposição em relação aos objetivos, apetite e tolerância, concentração, risco emergente, dependências sistêmicas e grandes decisões.

Análise de carteira

Agregar riscos com cuidado. Use taxonomia, objetivos, unidades de negócios, serviços, fornecedores e dependências de controle para identificar concentração e exposição sistêmica. Preservar a rastreabilidade aos cenários subjacentes.

Evitar somar pontuações ordinais como se fossem valores financeiros, a menos que a metodologia suporte explicitamente esse cálculo.

Controlos da qualidade dos dados

Monitor:

- Donos em falta
- Provas em falta ou antigas
- Datas de revisão excessivas
- Aceitações expiradas
- Cenários incompletos
- Notações inconsistentes
- Duplicar os riscos
- Acções não ligadas
- Acções fechadas sem validação
- Alterações não suportadas nas pontuações

Disciplina de reunião

Uma reunião de revisão de risco deve se concentrar em decisões, mudanças de evidência, exceções, ações atrasadas e escalada. Não passe a reunião lendo todos os campos em voz alta. Registre decisões, donos, datas de vencimento e dissidência.

6. Procedimento Operacional e Exemplo Trabalho

Procedimento de ponta a ponta

Etapa 1 — Estabelecer o âmbito de aplicação

Definir o objetivo, processo, serviço, projeto, unidade de negócio, grupo de ativos, população de fornecedores, ou decisão a ser avaliada. Confirmar o período de avaliação, a metodologia, os critérios de notação e a autoridade de decisão.

Passo 2 — Ajuntar evidência

Colete documentos atuais, relatórios de sistema, incidentes, resultados de teste, métricas, contratos, informações de arquitetura e entrada especializada. Gravar as datas e lacunas das provas.

Passo 3 — Escrever cenários

Descreva causa, evento, objetivo e consequência afetados. Separar cenários materialmente diferentes em vez de combinar exposições não relacionadas.

Etapa 4 — Atribuir propriedade

Diga um proprietário de risco responsável. Identifique os proprietários de controle e ação separadamente.

Etapa 5 — Avaliar a exposição inerente

Aplicar os critérios de verossimilhança e impacto aprovados utilizando o pressuposto de risco inerente declarado.

Etapa 6 — Avaliação dos controles

Documentar os controles pertinentes e avaliar a conceção e a eficácia operacional utilizando elementos de prova.

Etapa 7 — Avaliar a exposição residual

Estimar a probabilidade e o impacto remanescentes. Grave confiança, suposições e incerteza.

Passo 8 — Comparar com apetite e tolerância

Determinar se a exposição está dentro dos limites aprovados e se é necessária uma escalada.

Etapa 9 — Selecione resposta e tratamento

Escolha evitar, mitigar, transferir/compartilhar, aceitar ou perseguir/melhorar. Defina ações mensuráveis e exposição-alvo.

Passo 10 — Aprovar e monitorizar

Obter a decisão necessária, monitorar indicadores e ações, reavaliar após a mudança e preservar evidências.

Exemplo trabalhado

Objectivo

Mantenha o acesso contínuo à plataforma de suporte ao cliente durante períodos críticos de negócios.

Cenário

Como a plataforma depende de uma única região de nuvem e o teste de recuperação não demonstrou restauração dentro do requisito de negócios, uma interrupção regional do serviço pode tornar a plataforma indisponível, atrasando o suporte ao cliente e causando danos contratuais, financeiros e de reputação.

Provas

- Diagrama de arquitetura atual
- Análise de impacto empresarial
- Relatório do ensaio de recuperação
- Documentação do serviço de provedor de nuvem
- Compromissos de disponibilidade de contratos com clientes

Avaliação dos resultados

- Probabilidade: 3 — Possível
- Impacto: 5 — Grave
- Pontuação: 15 — Alta sob a matriz exemplo

Controles existentes

- Cópias de segurança nativas do provedor
- Configuração da infraestrutura armazenada no controle de versão
- Procedimentos de resposta a incidentes
- Monitorização da página de estado

Avaliação do controlo

O design é parcialmente eficaz porque backups e recuperação de suporte de configuração, mas não existe capacidade de região secundária. A eficácia operacional é parcialmente eficaz porque os trabalhos de backup são monitorados, enquanto a restauração completa não cumpriu o tempo de recuperação necessário.

Avaliação residual

- Probabilidade: 3 — Possível
- Impacto: 4 — Maior
- Pontuação: 12 — Alta
- Confiança: Médio
- Estado do apetite: Tolerância externa

Resposta

Mitigar.

Acções de tratamento

1. Projetar e aprovar arquitetura de regiões secundárias.
2. Implementar dados replicados e automação de implantação testada.
3. Realize um exercício de recuperação completo.
4. Atualizar procedimentos e comunicações do cliente.
5. Validar os objetivos de tempo de recuperação e ponto de recuperação.

Avaliação-alvo

- Verossimilhança-alvo: 2 — Improvável
- Impacto-alvo: 3 — Moderado
- Pontuação do alvo: 6 — Moderado

Acompanhamento

Acompanhe os resultados do teste de recuperação, falhas de replicação não resolvidas, marcos de arquitetura e tarefas de tratamento atrasadas. Escalar marcos perdidos ou qualquer falha que exceda a tolerância aprovada.

Falhas comuns de implementação

- Tratar a pontuação como o risco em vez do cenário
- Atribuir grupos em vez de proprietários responsáveis
- Controlos de registo sem provas
- Aceitar o risco indefinidamente
- Ações de encerramento sem reavaliar a exposição
- Utilização de provas antigas
- Combinando muitos riscos não relacionados em um registo
- Relatar apenas conta em vez de decisões e concentração

Aceitação de Risco Gravar

Informações de risco

- ID de risco:
- Título do risco:
- Objectivo afectado:
- Titular do risco:
- Probabilidade residual atual:
- Impacto residual atual:
- Nível residual atual:
- Confiança na avaliação:

Decisão

- Decisão: Aceitar / Condicionalmente aceitar / Rejeitar pedido de aceitação
- Autorizado proprietário da decisão:
- Base da autoridade:
- Data da decisão:
- Data de eficácia:
- Data de termo:

Razão

Descrever por que razão se justifica manter a exposição, incluindo o valor esperado das empresas, as alternativas disponíveis, os custos e a viabilidade e as consequências do atraso.

Apetite e tolerância

- Declaração de apetite aplicável:
- Tolerância ou limiar aplicável:
- Status: dentro / fora / exceção aprovada

Condições e controlos compensadores

Listar salvaguardas, restrições, monitoramento, comunicações e dependências necessárias.

Acompanhamento

- Principais indicadores de risco:
- Limiares:
- Controlador:
- Frequência de revisão:
- Localização da prova:

Desencadeios de reconsideração precoce

Exemplos incluem um incidente material, falha de controle, mudança legal ou contratual, aumento da exposição, mudança de objetivo, condição perdida ou nova informação de ameaça.

Notificações necessárias

Identificar órgãos, executivos, clientes, reguladores, seguradoras, partes contratuais ou funções internas que devem ser informadas.

Provas de aprovação

Registre a assinatura, bilhete, decisão de reunião, aprovação eletrônica ou outra autorização auditável.

Resultado da revisão

- Data de revisão:
- Resultado: Renovar / Tratar / Evite / Transferir ou compartilhar / Fechar
- Condições actualizadas:
- Próximo proprietário da ação:
- Próxima data de vencimento:

Registo Autoritativo de Código

Verificado em 1 de Agosto de 2026.

Fontes primárias

1. NIST IR 8286 Rev. 1, *Integrando Cybersecurity and Enterprise Risk Management (ERM)*, dezembro de 2025. <https://csrc.nist.gov/pubs/ir/8286/r1/final>
2. NIST IR 8286A Rev. 1, *Identificar e Estimar o Risco de Cibersegurança para Gestão de Risco Empresarial*, dezembro de 2025. <https://csrc.nist.gov/pubs/ir/8286/a/r1/final>
3. NIST IR 8286B, *Prioritizando o Risco de Cibersegurança para Gestão de Risco Empresarial*. <https://csrc.nist.gov/pubs/ir/8286/b/final>
4. NIST IR 8286C, *Staging Cybersecurity Risks for Enterprise Risk Management and Governance Oversight*. <https://csrc.nist.gov/pubs/ir/8286/c/final>
5. NIST SP 800-30 Rev. 1, *Guia para a realização de avaliações de risco*. <https://csrc.nist.gov/pubs/sp/800/30/r1/final>
6. NIST Framework de Cibersegurança 2.0. <https://www.nist.gov/cyberframework>

7. ISO 31000:2018, *Gestão do risco — Orientações*. A ISO identifica a edição de 2018 como atual e observa que a edição 3 está em desenvolvimento.
<https://www.iso.org/standard/65694.html>
8. Centro de Segurança da Internet, CIS RAM v2.2 família de documentos para Controles CIS v8.1. <https://learn.cisecurity.org/cis-ram-v2-2>

Utilização e limitações

Este manual resume práticas gerais de gestão de riscos e não reproduz normas restritas. As organizações devem verificar os requisitos atuais, as condições de licenciamento, as obrigações específicas do setor e sua própria metodologia aprovada antes do uso.